INFORME DE VULNERABILIDAD DE PHP: PHP2Shell

CVE-2026-109618 y CVE-2026-109619: descripción y parche aplicado en pnkSecurity

Fecha de emisión del informe	26/10/2026
Responsables	Savka Carvajal · Matías Nonque
Versión del informe	1.0 (complemento del Informe de remediación v2.2)
Clasificación del documento	Confidencial
Repositorio	https://github.com/matiasNon/pnkSecurity — rama mejoras-por-vul
Servidor AWS (revisión)	https://3.230.214.61/index.php?id=1 (certificado autofirmado)
Versión de PHP tras el parche	8.5.12 (última versión estable; incluye el parche de ambas CVE)

1. Resumen ejecutivo

El 21/10/2026 el proyecto PHP publicó una actualización de seguridad de emergencia para dos fallas críticas del propio intérprete, conocidas como **PHP2Shell**: CVE-2026-109618 y CVE-2026-109619. Ambas permiten ejecución remota de código (RCE) y tienen un puntaje CVSS v4.0 de **9,2**. El defecto no está en el código de la aplicación sino en el motor de PHP, por lo que las correcciones de código de las 12 vulnerabilidades del Informe de remediación (consultas preparadas, escape de salida, CSRF, etc.) **no la mitigan**: la única corrección completa es actualizar PHP.

pnkSecurity se ejecuta sobre PHP, y el despliegue de AWS usa Apache con mod_php, que es la configuración que el propio proyecto PHP señala como la más expuesta. Este informe describe la vulnerabilidad, su efecto sobre el proyecto y el parche. **Estado:** el entorno local ya fue actualizado de PHP 8.3.35 a **8.5.12** y verificado; la actualización del servidor de AWS se describe en la sección 4.3 y figura como **pendiente de aplicar y verificar** en la instancia (ver sección 5).

2. Descripción de la vulnerabilidad

Fuente principal: The PHP Foundation (aviso del 21/10/2026). Las dos fallas son errores de gestión de memoria que se disparan cuando una petición termina de forma anormal (por ejemplo, al alcanzar memory_limit) y dejan el estado interno de PHP dañado.

	CVE-2026-109618	**CVE-2026-109619**
Aviso (GHSA)	GHSA-w8hw-w9fx-j79w	GHSA-6wmf-4rv5-p3rp
Severidad	CVSS v4.0 9,2 (crítica)	CVSS v4.0 9,2 (crítica)
Causa raíz	Corrupción de memoria por falta de memoria (OOM): si una petición alcanza memory_limit en un momento preciso, PHP deja datos internos a medio inicializar y luego los trata como válidos.	Estado global obsoleto: un error fatal en un punto concreto deja el estado interno apuntando a memoria de una petición anterior; otra petición del mismo proceso puede usar esa memoria ya liberada (use-after-free).
Efecto	RCE. Con Apache + mod_php, una petición sin autenticación puede dispararla antes de que se ejecute cualquier código de la aplicación;	Use-after-free y caída del proceso; RCE demostrado contra una aplicación real con Apache + mod_php.

	demostrada con configuración por defecto. También confirmada en PHP-FPM a través de rutas de código de la aplicación.	
Corregida en	PHP 8.5.12, 8.4.27, 8.3.36 y 8.2.35	PHP 8.5.12, 8.4.27, 8.3.36 y 8.2.35

- **Qué NO es:** el puntaje oficial es 9,2. Circuló un 10,0 en reportes filtrados antes de la publicación; no es el oficial.
- **Línea de tiempo:** filtración del embargo el 20/10; publicación del parche el 21/10. Las fuentes discrepan sobre si hubo explotación activa antes del parche, por lo que se trata como riesgo real, sin afirmar un incidente.
- **Análisis independiente (Sansec):** caracteriza la primera falla como un use-after-free en el deserializador de upload_progress y la segunda como una confusión de tipos con OPcache; afirma que el código vulnerable viene desde PHP 5.4 y que todos los disparadores conocidos son peticiones multipart/form-data. Son detalles técnicos complementarios de un tercero; la descripción oficial es la del PHP Foundation.
- **Versiones sin parche upstream:** las ramas 8.0, 8.1 y anteriores no tienen versión corregida del proyecto; solo hay parches de las distribuciones (por ejemplo Debian/Ubuntu para 8.1). PHP 7.4 y 8.0 ya no reciben soporte de seguridad.

3. Efecto sobre pnkSecurity

Elemento	Situación antes del parche	Evaluación
Entorno local de laboratorio (C:\php)	PHP 8.3.35 (compilado el 22/09/2026), anterior al parche.	Vulnerable.
Servidor AWS (EC2 Ubuntu)	Apache + libapache2-mod-php (instalados con el script de despliegue local deploy/aws/user-data.sh, que no se publica en GitHub). La versión exacta depende de la imagen (Ubuntu 22.04 trae PHP 8.1; 24.04 trae PHP 8.3).	Configuración más expuesta (mod_php). Versión instalada no verificada desde este equipo.
Aplicación	No hay formularios con archivos ni multipart/form-data (login, comentarios y carrito usan application/x-www-form-urlencoded). El fallo se dispara antes del código de la aplicación.	La ausencia de subidas no elimina el riesgo; sí permite el bloqueo temporal de la sección 4.4 sin costo funcional.

Clasificación:

- **OWASP Top 10:2025:** A03 Software Supply Chain Failures (componente de terceros vulnerable, como VUL-12).
- **ASVS v5:** V15 Codificación segura y arquitectura (gestión de dependencias y componentes).
- **ISO/IEC 27001:2022:** A.8.8 Gestión de vulnerabilidades técnicas.
- **Severidad para el proyecto:** CRÍTICA mientras el servidor de AWS no esté parchado.

Este hallazgo coincide con la fila V15 del Informe de remediación, que ya marcaba «PARCIAL: falta revisión periódica de CVE de las demás librerías». PHP2Shell es un ejemplo concreto de ese punto.

4. Cómo lo parchamos

4.1 Elección de la versión

Se eligió **PHP 8.5.12**, la última versión estable publicada, que incluye el parche de ambas CVE. La rama 8.5 ya figuraba entre las versiones con las que se probó la aplicación (README). La corrección mínima habría sido PHP 8.3.36 (misma rama que se usaba antes); de hecho el 26/10/2026 se instaló primero esa versión y, a pedido del equipo, se subió después a 8.5.12. Ambas versiones corrigen PHP2Shell; en este informe queda como estado final del entorno local la 8.5.12.

4.2 Entorno local (aplicado el 26/10/2026)

Paso	Detalle	Resultado
1. Descarga	Compilación oficial php-8.5.12-1-nts-Win32-vs17-x64.zip desde downloads.php.net (la compilación vigente de 8.5.12).	Descargado (36 MB).
2. Integridad	SHA256 calculado = SHA256 del listado oficial: 2a36a2edcb7a5b9252f638fd5e4cf84d7f6e066092654220dc0b63e5cf4e9723	Coincide (Figura PHP-2).
3. Respaldos	Copia completa de C:\php antes de cada cambio: C:\php-8.3.35-backup (original, vulnerable) y C:\php-8.3.36-backup (paso intermedio).	Respaldos verificados (Figuras PHP-1 y PHP-3).
4. Actualización	Se reemplazaron los archivos de PHP y la carpeta ext por los de 8.5.12, conservando el php.ini propio.	Sin errores.
5. Ajuste de php.ini	Se comentaron session.sid_length = 26 y session.sid_bits_per_character = 5: obsoletas desde PHP 8.4 y generaban avisos al arrancar. Son los valores por defecto, así que no cambia el comportamiento.	Sin avisos (Figura PHP-5).
6. Versión	php -v	PHP 8.5.12 (cli) (built: Oct 26 2026 09:51:07), Zend Engine v4.5.12 (Figura PHP-4).
7. Extensiones	php -m	mbstring y mysqli cargadas.
8. Sintaxis	php -l sobre los 7 archivos PHP de la aplicación.	0 errores (Figura PHP-5).

Alcance de la prueba local: no se ejecutó la aplicación completa en el equipo de trabajo, porque la base de datos local exige una clave que no forma parte del proyecto. La verificación funcional completa se hace en AWS (sección 5).

Marcha atrás: borrar C:\php y renombrar el respaldo elegido (C:\php-8.3.36-backup o C:\php-8.3.35-backup) a C:\php.

Evidencias del cambio de versión

Capturas de la consola con la salida real de cada comando, generadas el 26/10/2026 en el equipo de trabajo (archivos originales en docs/evidencias-php/). En las figuras PHP-2 y PHP-5 el comando se muestra abreviado.

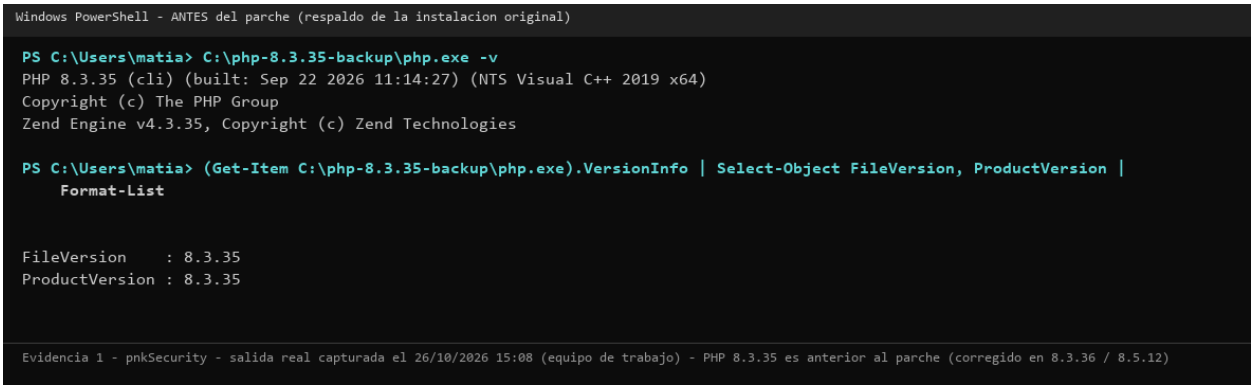


Figura PHP-1 — Antes: PHP 8.3.35 (anterior al parche), según el respaldo de la instalación original.

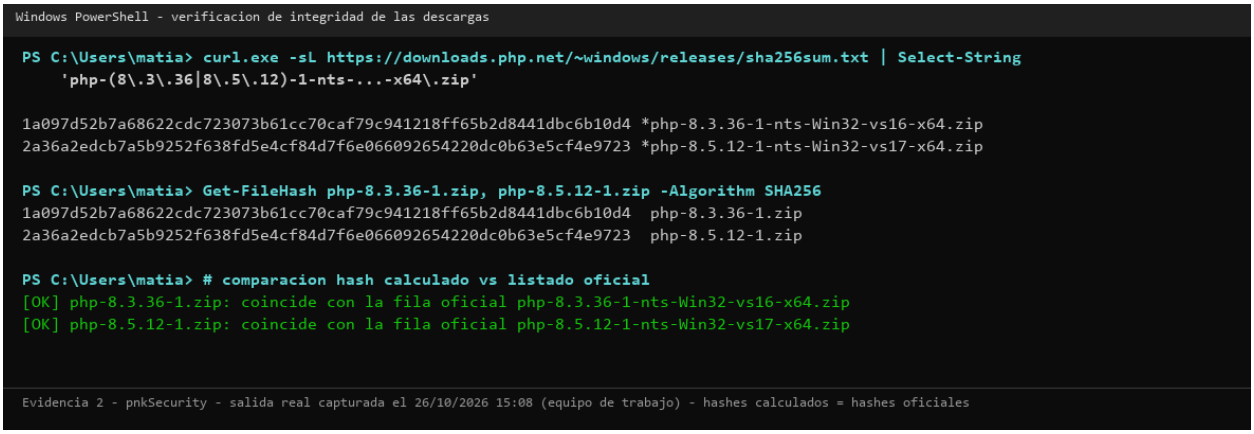


Figura PHP-2 — Integridad: los SHA256 de los zip descargados coinciden con el listado oficial de downloads.php.net.

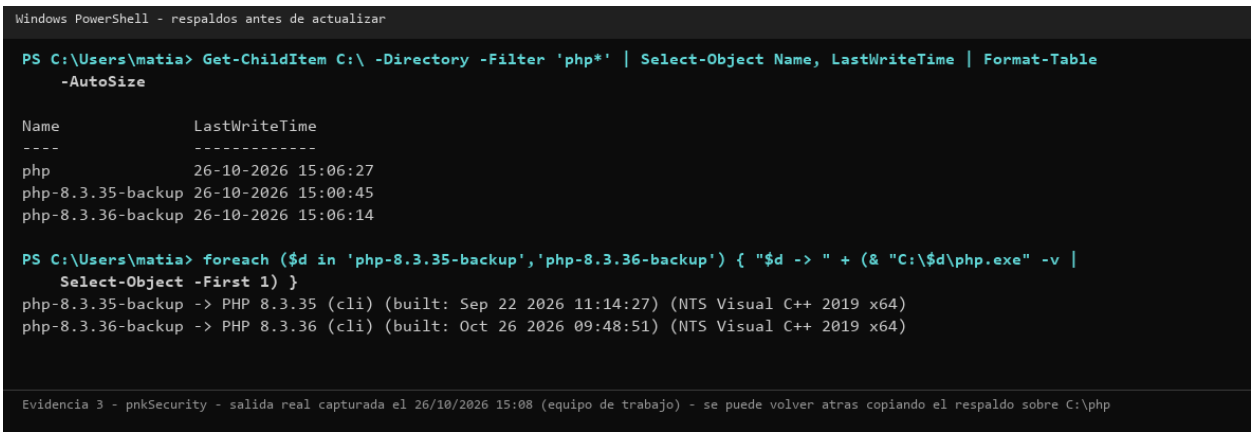


Figura PHP-3 — Respaldos de 8.3.35 y 8.3.36 creados antes de actualizar.

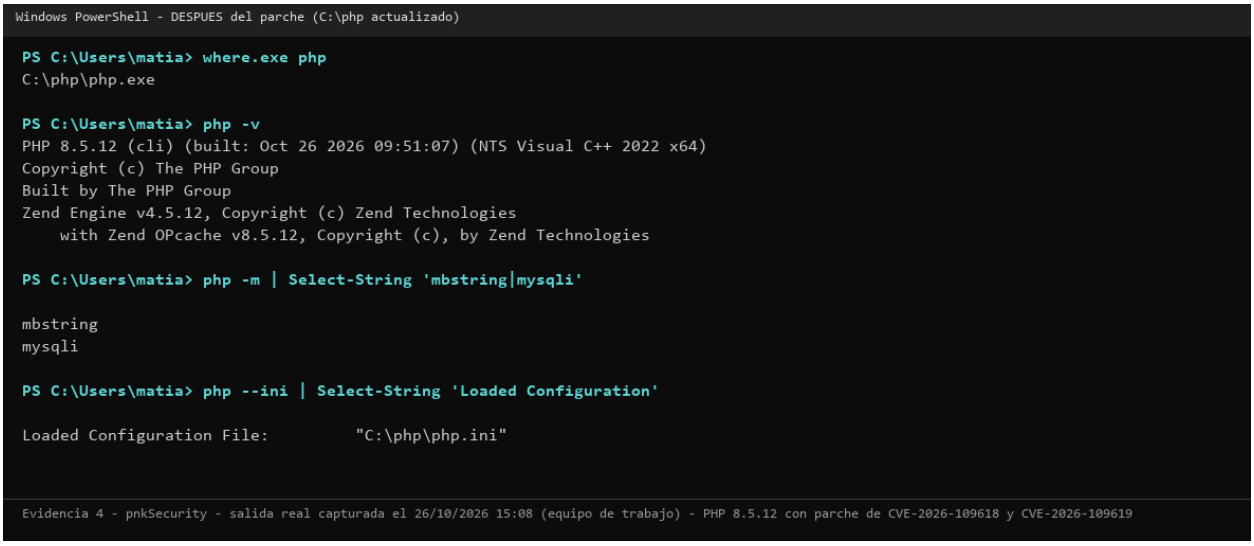


Figura PHP-4 — Después: PHP 8.5.12 en C:\php, con mbstring y mysqli cargadas y el php.ini original.

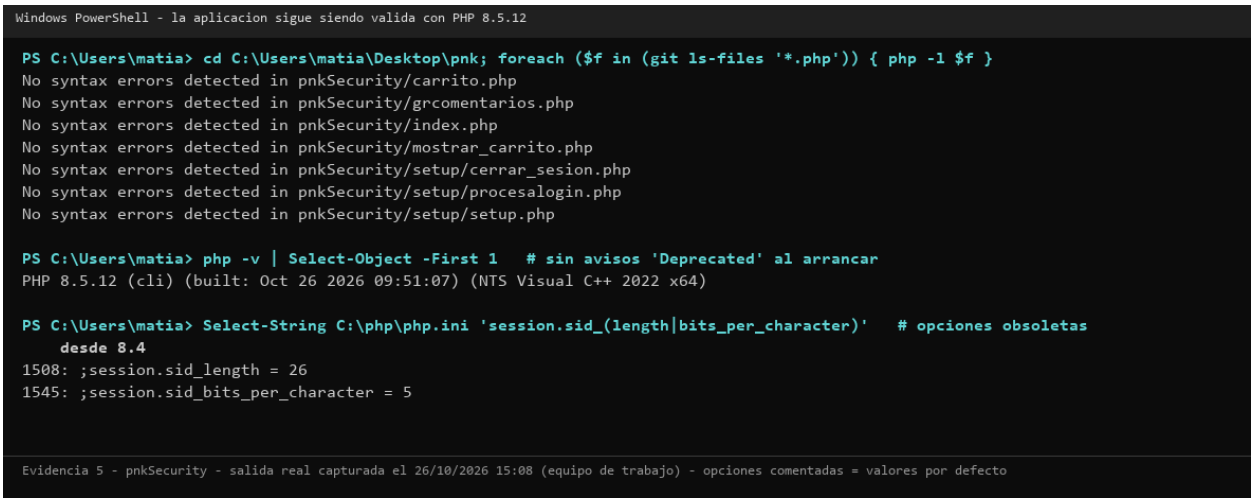


Figura PHP-5 — La aplicación sigue siendo válida con 8.5.12 (7 archivos sin errores de sintaxis) y sin avisos al arrancar.

4.3 Servidor AWS (procedimiento; pendiente de aplicar)

No se tiene acceso remoto a la instancia desde el equipo de trabajo, por lo que este paso lo ejecuta el equipo por SSH o EC2 Instance Connect. En Ubuntu el número de versión **no** sirve para comprobar el parche (por ejemplo, Ubuntu 22.04 sigue mostrando 8.1.x): se verifica con el registro de cambios del paquete.

A. Ver qué hay instalado

```
php -v
apache2ctl -M | grep -i php
dpkg -l | grep -E 'php[0-9.]*-common|libapache2-mod-php'
```

B. Actualizar con los repositorios oficiales de la distribución y reiniciar Apache

```
sudo apt-get update
sudo apt-get install --only-upgrade -y 'php*' 'libapache2-mod-php*'
sudo systemctl restart apache2        # obligatorio: mod_php carga PHP dentro de Apache
```

C. Comprobar que el parche está incluido (cambiar 8.1 por la versión que mostró el paso A)

```
zgrep -c 'CVE-2026-109618' /usr/share/doc/php8.1-common/changelog.Debian.gz
zgrep -c 'CVE-2026-109619' /usr/share/doc/php8.1-common/changelog.Debian.gz
```

Si ambos comandos devuelven 1 o más, el parche ya está incluido. Según el rastreador de seguridad de Ubuntu, las versiones corregidas son php8.1 8.1.2-1ubuntu2.28 (Ubuntu 22.04) y php8.3 8.3.6-0ubuntu0.24.04.13 (Ubuntu 24.04). Si devuelven 0, la distribución aún no lo publicó y hay que pasar al paso D.

D. Alternativa si la distribución aún no lo publica: PHP desde el PPA de Ondřej Surý (8.3.36 es el mínimo corregido; si el PPA ofrece php8.5, se puede instalar 8.5.12 igual que en el equipo local; verificar antes con apt-cache policy php8.3)

```
sudo add-apt-repository -y ppa:ondrej/php
sudo apt-get update
apt-cache policy php8.3                # debe ofrecer 8.3.36 o un paquete con la corrección
sudo apt-get install -y php8.3 libapache2-mod-php8.3 php8.3-mysql php8.3-mbstring
sudo a2dismod php8.1 2>/dev/null; sudo a2enmod php8.3
sudo systemctl restart apache2
```

4.4 Mitigación temporal (solo hasta aplicar el parche)

Según el análisis de Sansec, todos los disparadores conocidos son peticiones multipart/form-data. Como pnkSecurity no recibe archivos, se puede rechazar ese tipo de petición sin romper ninguna función. **No reemplaza la actualización.**

```
# dentro de <VirtualHost *:443> y <VirtualHost *:80> en /etc/apache2/sites-available/pnk.conf
RewriteEngine On
RewriteCond %{HTTP:Content-Type} ^multipart/form-data [NC]
RewriteRule ^ - [F]
```

- Añadir php_admin_flag session.upload_progress.enabled off (o session.upload_progress.enabled = Off en php.ini) y reiniciar Apache.
- **No se adopta** la sugerencia de poner memory_limit en -1: en una instancia pequeña (t3.micro) una sola petición podría agotar toda la memoria del servidor.

5. Verificación y estado

Comprobación	Cómo	Estado
PHP local en 8.5.12	php -v en el equipo de trabajo (Figura PHP-4)	Aplicado y verificado (26/10/2026)
Aplicación sin errores de sintaxis	php -l en 7 archivos con PHP 8.5.12 (Figura PHP-5)	Verificado (0 errores)
PHP del servidor AWS parchado	Sección 4.3, pasos A a C (registro de cambios con ambas CVE)	**Pendiente**
Aplicación sana tras el parche en AWS	curl -k -I https://3.230.214.61/index.php?id=1 debe dar 200; con id=1 OR 1=1 debe dar 404	**Pendiente**
Pruebas de las 12 VUL en AWS	python pruebas/probar_vulnerabilidades.py https://3.230.214.61 --insecure (script local, no publicado en GitHub): todo en PASS	**Pendiente**

Los puntos pendientes se cierran ejecutando la sección 4.3 en la instancia y anotando aquí la salida de los comandos de verificación.

6. Riesgo residual y recomendaciones

- **Prioridad 1:** parchar PHP en la instancia de AWS (sección 4.3) y reiniciar Apache. Hasta entonces el servidor es vulnerable aunque la aplicación esté corregida.
- Si el parche demora, aplicar de inmediato la mitigación de la sección 4.4.
- No usar PHP 7.4 ni 8.0 (sin soporte de seguridad). El README indica que la aplicación se probó en 7.4; conviene recomendar solo 8.3 o superior.
- Incorporar al proceso una revisión periódica de avisos de PHP y de las librerías de vendors/, que es lo que la fila V15 del informe de remediación dejaba como parcial.
- Tras el parche, revisar el registro de errores de Apache buscando caídas de procesos (segfault) entre el 21/10 y la fecha de actualización, como indicio de intentos de explotación.

7. Fuentes

- The PHP Foundation, «Today's PHP Security Release, and How We're Strengthening PHP Security» (21/10/2026): https://thephp.foundation/blog/2026/10/21/todays-php-security-release-and-how-were-strengthening-php-security/
- Sansec, «PHP2Shell: PHP RCE (CVE-2026-109618, CVE-2026-109619)»: https://sansec.io/research/php2shell
- PHP, descargas para Windows y listado de sumas SHA256: https://downloads.php.net/~windows/releases/
- Informe de remediación de pnkSecurity v2.2 (docs/INFORME_REMEDIACION_pnkSecurity) y guía local deploy/aws/README.md (no publicada en GitHub).